Universiteit van Amsterdam
Amsterdam Business School

Cyber Risk Management and Threat Landscape

"A management perspective on inevitable cyber risks"

Rob Havermans

Agenda

1. Short lookback to last week's class
2. Positioning cybersecurity correctly
3. Threat landscape overview
4. Business impact assessment
5. Real-world case studies
6. Closing: key takeaways for managers

Dear mr. / mrs. CISO*, welcome in this meeting. We have a question for you. Are we secure ?

CISO = Chief Information Security Officer

What do you think your role and responsibility is in this ?

Potential responses might be:
“What do you base that on ?”
“I do not agree.”
“What about that incident the other day ?”
“But what about all these issues related to security process XYZ ?”

Potential thoughts might be:
“What an ad-hoc way of managing such an important topic.”
“I do not trust this CISO, I do not think he/she is competent.”
“I understand nothing of cybersecurity, how boring.”
“This CISO lives in perfect isolation, yet another specialist.”

There is a difference between cause and effect

1 + 2 + 3 = Information Security Risk Scenario's ("what could go wrong ?")

1 = Actor with motivation	2 = Risk / Threat / Attack Vector	3 = Protective measures
Intentional malicious behaviour Unintentional malicious behaviour Internal External	Ransomware Attack DDoS-Attack Access Misuse/Abuse Physical Intrusion ……..	Many possibilities, we will tackle this later

Impact on

Cyber risk as a business risk

Comparable to Financial Risk

Cyber risk can lead to significant financial losses through theft, fraud, and recovery costs, similar to traditional financial risks organizations face.

Comparable to Legal Risk

Regulatory fines, breach notification requirements, and contractual liabilities make cyber risk a critical legal concern for organizations.

Comparable to Supply Chain Risk

Vulnerabilities in third-party vendors and partners can propagate cyber threats, mirroring supply chain disruptions in business operations.

Comparable to Operational Risk

Cyber incidents can disrupt business processes, halt production, and impact service delivery, causing operational challenges.

What is Cybersecurity?

Confidentiality

Ensures sensitive information is accessible only to authorized individuals, preventing unauthorized disclosure and data breaches.

Integrity

Maintains accuracy and trustworthiness of data by preventing unauthorized modification, ensuring that information remains complete and unaltered.

Availability

Guarantees that information and systems are accessible and operational when needed, minimizing downtime and ensuring business continuity.

Introduction to risk management

[Interactive exercise]

1. Everybody please stand up
2. Put your phone in one hand, and something else in your other hand.

3. Please raise your hand with the most valuable asset.

4. There is a threat. A one-armed bandit is in the room and will take something from one of you every 10 minutes. This person is stronger in that one arm than you are in one arm. But with both hands you are stronger. Choose to keep both items in one hand, or to drop one thing and hold on to the other with both hands.

5. Pick up the dropped item and hold one in each hand again. The threat is still here but reduced, the one-armed bandit will only appear once during this class. Again, choose to keep both items in one hand, or to drop one thing and hold on to the other with both hands.

What are we talking about ?

- What is the information security risk profile of your organization ?
- What is the concern of your management ?
- What should be the concern of your management ?
- What is the expectation of your management from you ?
- What is your actual area of responsibility ?
- What can you deliver on ?
- What language is used, and is that understood by all relevant stakeholders ?
- What is your actual information security risk profile today ?
- How do you know ?
- Where do you want to go, and why, and does everyone agree ?
- How do you know you are there, when you are ?
- ……

What are we also talking about ?

- Is it OK not to patch this asset ?
- Is it OK to buy this software asset ?
- Is it OK to work with this vendor ?
- Is it OK to use simple passwords ?
- Is it OK to not deliver log files ?
- Is it OK to test with production data ?
- Is it OK to provide these access rights ?
- Is it OK to……

Introduction to risk management

ISO 31000 Risk Definition

Risk is defined as the effect of uncertainty on objectives, meaning it encompasses both potential threats and opportunities that impact achieving business goals.

ISO 27001 Focus

ISO 27001 provides practical guidance to manage information security risk, integrating controls and processes into organizational governance.

Risk is Linked to Objectives

Risk only exists if there are objectives to achieve; it is inseparable from organizational goals and strategy, emphasizing that risk management supports business success.

Managing Uncertainty

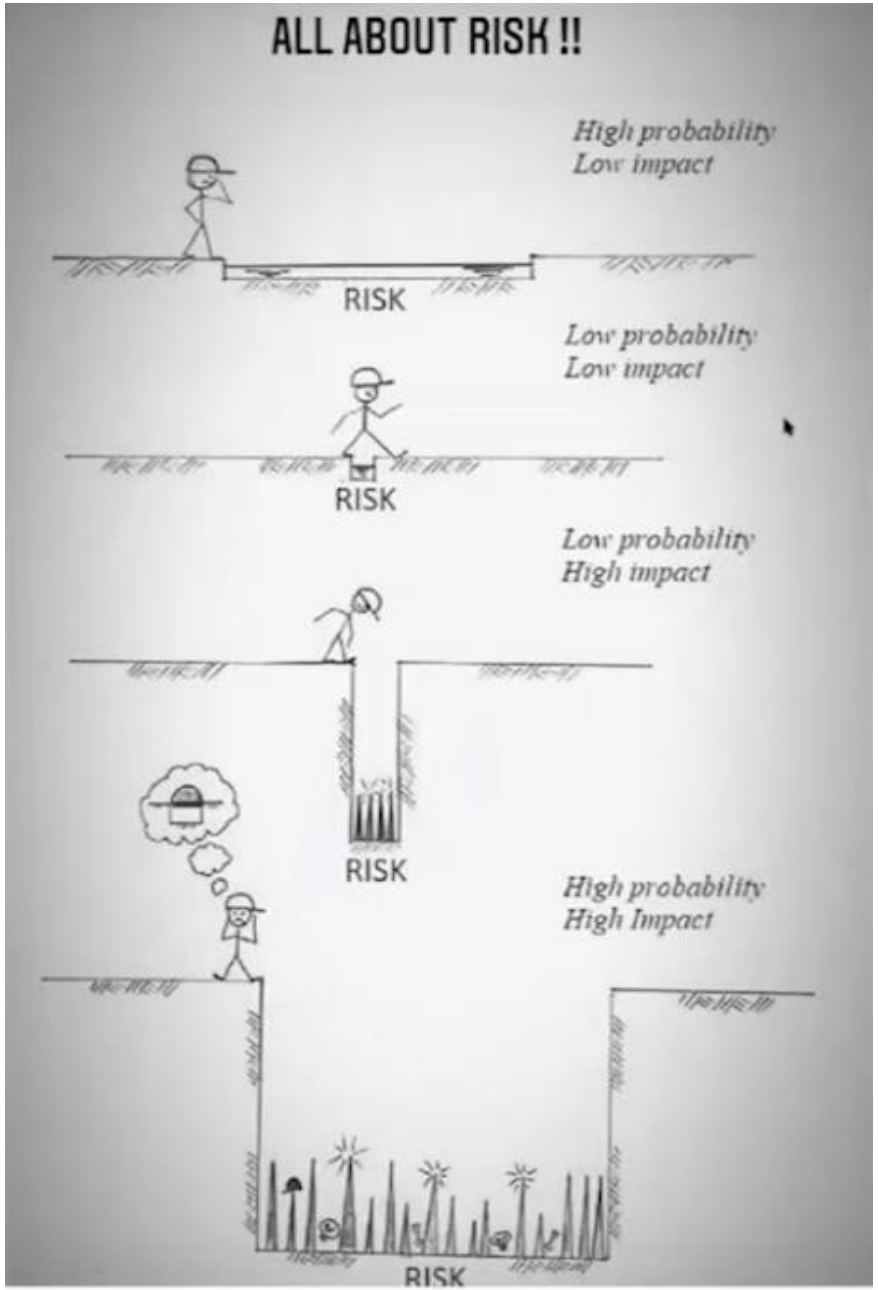
Uncertainty is unavoidable; risk management is about navigating it effectively to protect value and enable informed decision-making rather than trying to eliminate all risks.

What is a risk ?

Risk = Probability x Impact

What is a risk ?

Risk = Probability x Impact



What is a risk ?

Risk = Threat × Vulnerability × Impact

IT asset
Information asset
Weakness

Shortcomings of risk management in this space

Risk = Likelihood × Impact

The problem:
- Likeliho
- Impact i
- Historic

Risk = Thre

The proble
- Threat l
- Human

Overall

The proble
- "Low probability, high impact" risks are dismissed
- Interdependencies and cascading failures are ignored
- Risk management assumes rational decision-making
- Over-focus on compliance, not reality

Risk management in cyber security is necessary—but insufficient—because it simplifies a fast-moving, human-driven, adversarial problem into static models.

Risk or Uncertainty

Risk

Measurable and quantifiable with known probabilities.

Uncertainty

Unknown and unmeasurable; outcomes and probabilities are unclear.

Prof. Dr. Martijn Dekker on Uncertainty

- https://martijn-dekker.medium.com/managing-information-security-is-managing-uncertainty-1f8c17148e45
- https://www.martijndekker.eu

Then what is the added value of risk management ?

Risk management is about making choices
Risk management is about setting priorities
Risk management is about communications and a common language
Risk management is about embedding a clear and structured process
Risk management is a tool to help you do your work and to enable you to segregate opinions and discussions from decision making

Risk management is not exact science
Risk management does not deal with true or false
Risk management does not replace common sense or good communication skills

If risk is about achieving objectives, what are your objectives, and what risks am I managing [EXAMPLE]?

1. We want to be a (highly) reliable services provider to our customers
2. We want to be innovative with a short time-to-market with new products and services
3. We want to be a premium brand (high quality for a premium price), or we want to be a budget brand (reasonable quality for a low price).
4. We want to….

What does that mean ?

1. We want our customers to be able to use our services always, with a high-level of reliability, with an uptime of 99,5%
2. We want to protect the data that our customers put to us
3. We are willing to take little/medium/high risk

Security Top Risks

The Security Top Risks might have a potentially very high impact for our organization if those risks occur.

A. *Data and systems are unavailable*

1. Customers are unable to use to our online service channels, as a consequence of DDoS-attacks.
2. Our internal processes are significantly impacted, as a result of (un)targeted cybercrime.
3. Our internal processes are significantly impacted, as a result of abuse of (excessive) system authorisations (insider threat).

B. *Integrity of data is corrupted*

4. Money loss or liquidity issues arise, as a result of (un)targeted cybercrime.
5. Money loss, liquidity issues, operational errors arise, as a result of abuse of (excessive) system authorisations (insider threat).
6. We and/or clients loose money, as a result of fraud / cybercrime on our online service channels.

C. *Confidential data is publicly exposed or ends up in the wrong hands*

7. We are fined or publicly exposed for losing confidential data (organisational, employee or customer), which is lost by an employee.
8. We are fined or publicly exposed for losing confidential data (organisational, employee or customer), which is stolen by an employee (insider).
9. We are fined or publicly exposed for losing confidential data (organisational, employee or customer) as a result of (un)targeted cybercrime (outsider).

D. *Staff and/or assets are physically damaged*

10. People or assets are damaged as a consequence of inadequate protected facilities;

E. *We are held liable for not being in-control*

11. We get fines or sustain brand damage because relevant security-related laws and regulations are not complied with;
12. We run into operational issues or get fined because services provided to us by vendors are not (demonstrably) meeting security requirements.

What could go wrong ?

1 + 2 + 3 = Information Security Risk Scenario's ("what could go wrong ?")

1 = Actor with motivation	2 = Risk / Threat / Attack Vector	3 = Protective measures
Intentional malicious behaviour Unintentional malicious behaviour Internal External	Ransomware Attack DDoS-Attack Access Misuse/Abuse Physical Intrusion ……..	Many possibilities, we will tackle this later

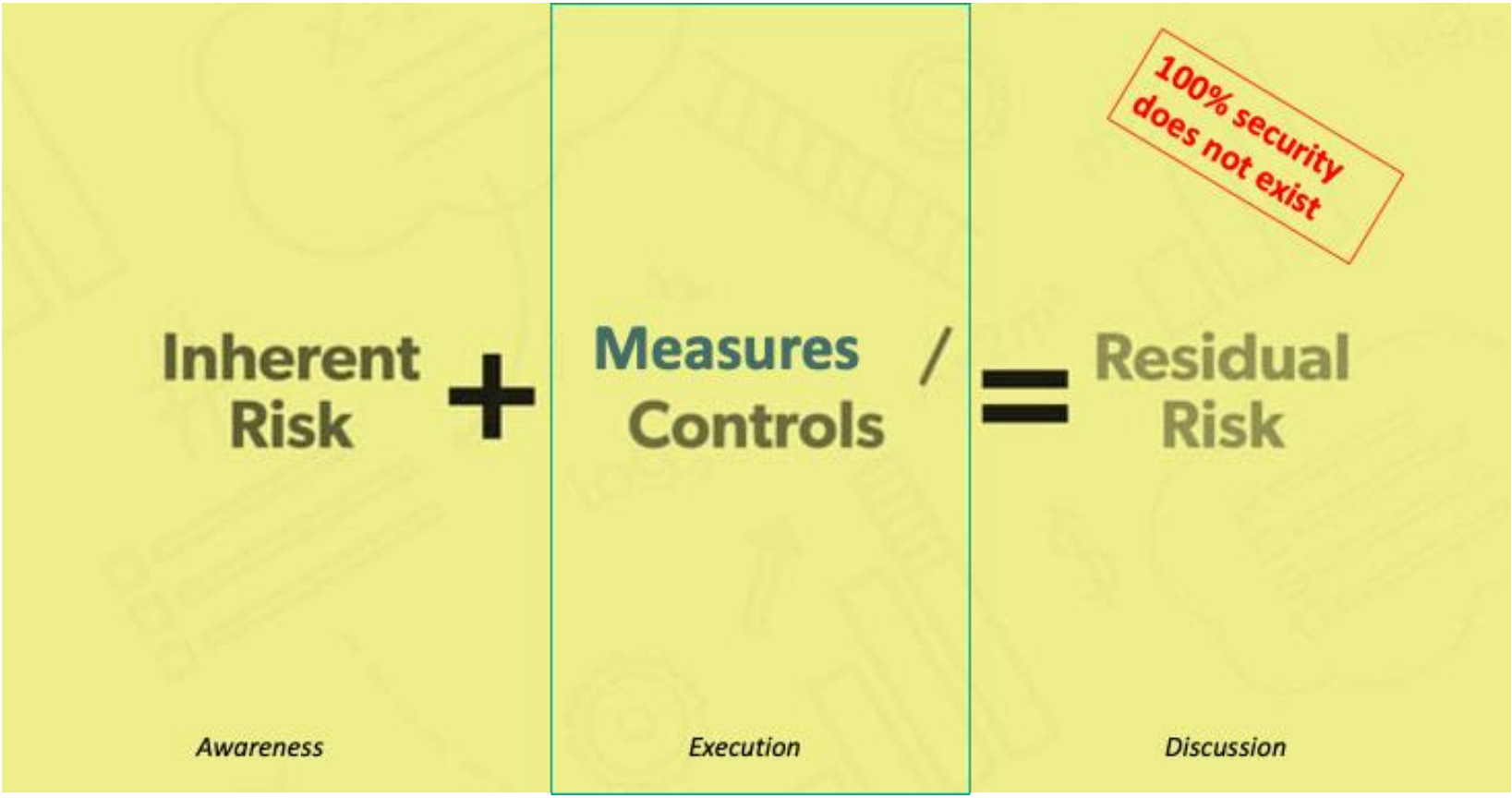
Impact on

What is a risk ?

Risk = Threat × Vulnerability × Impact

IT asset
Information asset
Weakness

Risks versus controls



Inherent, Control, and Residual Risk

01

Inherent Risk

Inherent risk is the natural level of risk present before any controls are applied, reflecting the exposure of assets to threats based on their environment and value.

02

Examples of Inherent Risk

An internet-facing system holding sensitive data faces high inherent risk, while an offline archival system typically has low inherent risk due to limited exposure.

03

Control Risk

Control risk is the risk that existing security controls may fail to prevent or detect threats, depending on how well controls are designed and implemented.

04

Examples of Control Risk

Weak password policies increase control risk, whereas strong multi-factor authentication reduces the likelihood that controls will fail.

05

Residual Risk

Residual risk is the remaining risk after controls are applied; it acknowledges that no control can completely eliminate risk, requiring ongoing management and monitoring.

06

Managing Residual Risk

Organizations must accept and manage residual risk using monitoring, contingency planning, and strategies like insurance to mitigate impact from unknown or new threats.

Control Types

Preventive Controls

These controls aim to stop cyber incidents before they occur, such as strong passwords, access controls, firewalls, and security awareness training that prevent unauthorized access.

Detective Controls

Designed to identify and alert on incidents early, examples include intrusion detection systems, log monitoring, and security event alerts that help detect breaches quickly.

Corrective Controls

Actions and tools to limit damage and restore systems after an incident, like data backups, patch management, and incident response plans that recover operations.

Control Categories

Controls are classified as technical (encryption, firewalls), administrative (policies, training), or physical (locks, surveillance), combining multiple types strengthens overall security.

Control areas

Organizational Information Security

1. Governance

- Inf. Security Policies & Standards
- Inf. Security Risk & Compliance
- Inf. Security Metrics & Reporting
- Inf. Security Strategy
- Inf. Security Organization

2. Identify

- Asset Classification
- Asset Inventory
- Threat Identification
- Third-party Security Risk Mgmt
- Vulnerability Management
- Red Teaming
- Penetration Testing
- Physical Security Risk Mgmt

3. Protect

- Identity Management Employee
- Authentication Employee
- Authorisation Employee & Role Mgmt
- Privileged Access Management
- API Security
- Network Security
- Data Encryption & Key Mgmt
- Secure Configuration
- Secure Code
- Endpoint Protection
- DDoS Protection
- Data Loss Prevention
- Inf. Security Awareness & Training

4. Detect

- Infra Security Logging & Monitoring
- Appl. Security Logging & Monitoring
- Notice & Take Down
- Shadow IT

5. Respond

- Inf. Security Incident Response
- Inf. Security Issue Management

6. Recover

- Cyber Recovery

Alternative strategies to control implementations

Mitigate Risk Reduce the likelihood or impact of risk by implementing controls such as multi-factor authentication, encryption, or staff training to lower vulnerabilities.

Transfer Risk Shift risk to a third party through mechanisms like cyber insurance or outsourcing to manage potential financial or operational impacts.

Avoid Risk Eliminate the risk by changing or stopping risky activities, such as discontinuing use of unsupported software that poses security vulnerabilities.

Accept Risk Consciously tolerate residual risk when mitigation costs outweigh benefits, with documented approval and ongoing monitoring of the risk environment.

Risk Management Process

01 Establish Context

Define the external and internal environment, set risk criteria, and clarify organizational objectives to frame the scope and boundaries for managing risk.

- Context statement
- Risk criteria document
- Stakeholder analysis

02 Risk Identification

Systematically identify potential risks that could impact the achievement of objectives by examining sources of uncertainty, events, and their causes.

- Risk register
- List of identified risks
- Documentation of risk sources and events

03 Risk Analysis

Analyze identified risks to understand their nature, likelihood, and potential consequences, enabling prioritization based on impact and probability.

- Risk assessment report
- Risk matrix
- Likelihood and impact evaluation

04 Risk Evaluation

Compare analyzed risks against established criteria to determine which risks require treatment and prioritize action based on organizational risk appetite.

- Risk prioritization list
- Risk acceptance decisions
- Risk tolerance thresholds

05 Risk Treatment

Select and implement appropriate measures to mitigate, transfer, avoid, or accept risks, ensuring controls are effectively applied to reduce exposure.

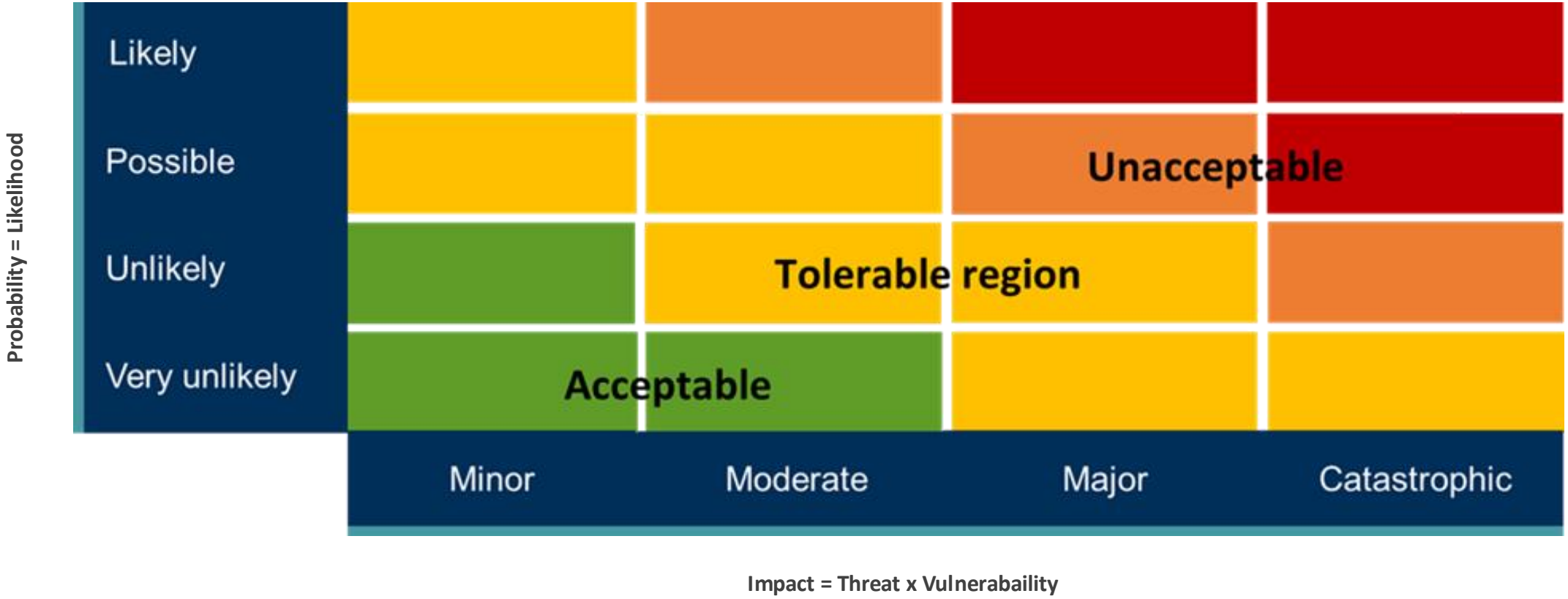
- Risk treatment plans
- Control implementation records
- Risk mitigation strategies

06 Monitoring and Review

Continuously monitor risks, controls, and the external environment to ensure the risk management process remains effective, relevant, and responsive to change.

- Monitoring reports
- Audit results
- Updated risk register

(Residual) risk tables



Short exercise I

- You are a trading company with a website for general information and contact details. You receive threat intelligence that DDoS-attacks are rising in your sector in your country. You have no DDoS-protection. How would you rate this risk ? Why ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	X	H	H	E
C (possible)	L	M	M	H	E
D (unlikely)	L	M	M	M	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Short exercise I

- You are a trading company with a website for general information and contact details. You receive threat intelligence that DDoS-attacks are rising in your sector in your country. You have no DDoS-protection. How would you rate this risk ? Why ?

- Your company intends to launch a web shop that needs to generate significant revenue with retail customers. No DDoS-protection designed. What would your risk evaluation and advice be ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	M	H X	H	E
C (possible)	L	M	M	H	E
D (unlikely)	L	M	M	M	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Short exercise I

- You are a trading company with a website for general information and contact details. You receive threat intelligence that DDoS-attacks are rising in your sector in your country. You have no DDoS-protection. How would you rate this risk ? Why ?

- Your company intends to launch a web shop that needs to generate significant revenue with retail customers. No DDoS-protection designed. What would your risk evaluation and advice be ?

- A security test also shows that your web shop is insecurely connected to your company network, which contains sensitive data on your customers and their data. How do you react ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	M	H	H X	E
C (possible)	L	M	M	H	E
D (unlikely)	L	M	M	M	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Short exercise I

- You are a trading company with a website for general information and contact details. You receive threat intelligence that DDoS-attacks are rising in your sector in your country. You have no DDoS-protection. How would you rate this risk ? Why ?
- Your company intends to launch a web shop that needs to generate significant revenue with retail customers. No DDoS-protection designed. What would your risk evaluation and advice be ?
- A security test also shows that your web shop is insecurely connected to your company network, which contains sensitive data on your customers and their data. How do you react ?
- Your company decides to implement DDoS-protection but not to further secure the connectivity issue. How does this translate in the table ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	M	H	H	E
C (possible)	L	M	M	H	E
D (unlikely)	L	M	M	M X	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Short exercise II

- You identified an internet-facing application where privileged access rights to the database with sensitive customer information are not properly managed and always available to multiple users
- How would you rate this risk to the application or process owner ? Why ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	M	H	H	E
C (possible)	L	M	M	X	E
D (unlikely)	L	M	M	M	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Short exercise II

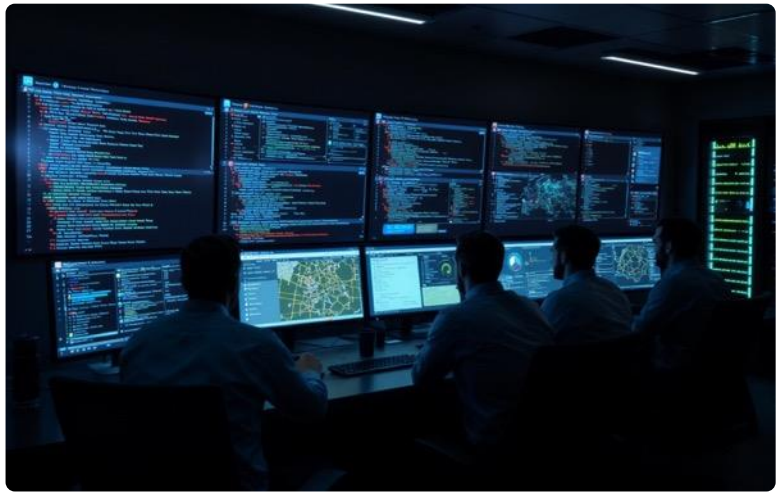
- You identified an internet-facing application where privileged access rights to the database with sensitive customer information are not properly managed and always available to multiple users
- How would you rate this risk to the application or process owner ? Why ?
- For the rest the organization has no significant security concerns. How would you rate the overall company security risk profile to the CEO of the organization ?

Qualitative Risk Analysis Matrix - Level of Risk *

Likelihood	Consequences				
	Insignificant 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
A (almost certain)	M	H	H	E	E
B (likely)	M	M	H	H	E
C (possible)	L	X	M	X	E
D (unlikely)	L	M	M	M	H
E (rare)	L	L	M	M	M

* Level of risk:	(E)	Extreme risk - detailed action/plan required
	(H)	High risk - needs senior management attention
	(M)	Moderate risk - specify management responsibility
	(L)	Low risk - manage by routine procedures

Discussion on different levels



Strategic Level

Focuses on the overall organization's security posture, evaluating risk exposure and alignment with business objectives at the highest leadership level.

Tactical Level

Centers on departments or business units, assessing risk management effectiveness and security controls to support strategic goals.

Operational Level

Involves specific business processes or applications, focusing on day-to-day security controls, incident handling, and process improvements.

And not done as a one-off exercise

ISO 27001

Risk appetite, what is our ambition ?

According to **ISO 31000:2018**, risk appetite is defined as:

“The amount and type of risk that an organization is willing to pursue or retain.”

Risk appetite, what is our ambition ?

Classic risk appetite statements focus on losses, that does provide insight but limited steering mechanisms

Low

We have a Moderate risk appetite

High

E.g. We do not want more than X data losses

E.g. We do not want more than X euro financial losses

E.g. We do not want more than X% of downtime

Risk Assessments on Different Levels

Strategic Risk Assessments

Focus on identifying and prioritizing risks that impact long-term organizational goals and overall business objectives, guiding senior management decisions.

Process-Level Risk Assessments

Analyze risks within specific business processes to identify failure points and implement controls that ensure process objectives are met reliably and securely.

Asset-Level Risk Assessments

Classify and evaluate individual assets based on their confidentiality, integrity, and availability needs to prioritize protections against threats and vulnerabilities.

Asset-Level Risk Assessment

Classifying assets by the CIA triad helps prioritize security efforts by aligning protection with business value and threat exposure.

CIA Triad and Threat Assessment

Asset-level risk assessment starts by classifying assets based on the CIA triad: Confidentiality, Integrity, and Availability. Confidentiality protects sensitive data from unauthorized access. Integrity ensures data accuracy. Availability guarantees access when needed.

The assessment then identifies threats and vulnerabilities that could impact these attributes, enabling focused risk management.

Key Points

- Classify assets by confidentiality, integrity, and availability needs
- Assess threats specific to each CIA attribute
- Prioritize security based on asset criticality
- Use results to guide risk mitigation

Process-Level Risk Assessment

Define Process Objectives

Clearly articulate what the process aims to achieve, focusing on outcomes and security goals that align with organizational priorities.

- Process objectives statement
- Scope definition
- Key performance indicators (KPIs)

Identify Risks

Analyze the process to detect potential risks, vulnerabilities, and failure points that could prevent the achievement of objectives.

- Risk identification log
- List of potential failure points
- Cause-and-effect diagrams

Implement Controls

Design and apply preventive, detective, and corrective controls tailored to mitigate identified risks and reduce their impact or likelihood.

- Control implementation plan
- Control descriptions and responsibilities
- Risk mitigation strategies

Monitor and Review

Continuously assess control effectiveness, review risk status, and adjust processes or controls to respond to changes and emerging threats.

- Monitoring reports
- Control effectiveness assessments
- Process improvement recommendations

Strategic risk assessments

01 Purpose of Strategic Risk Assessments

Focus on identifying and prioritizing strategic information security risks that could impact long-term business goals and organizational objectives.

02 Assessment Process

Evaluate the likelihood and impact of identified risks, then assess current mitigation efforts to determine if they adequately address these risks.

03 Management Intervention

If risks are not sufficiently mitigated, escalate findings to senior management for resource allocation, policy changes, or strategic adjustments.

04 Examples of Strategic Security Risks

Risks may include data breaches affecting customer trust, regulatory non-compliance penalties, disruption from cyberattacks on critical infrastructure, and intellectual property theft harming competitive advantage.

So, what threats are out there ?

- Many sources available which can be used as inputs to your risk assessments.

Source: Cyber Management Alliance

Vulnerabilities are not only technical

Technical vulnerabilities

IT systems can contain technical weaknesses which can be exploited. Poorly designed software, vulnerable third-party components, old technology, etc. These vulnerabilities are abundant and require continuous attention through scanning and remediation.

Human Factors

Human error causes over half of security breaches, including weak passwords, falling for phishing scams, and sending out sensitive information. Training and awareness are essential to reduce these risks.

Organizational Culture

A weak cybersecurity culture with poor communication and lack of leadership engagement fosters risky behaviors and inhibits open reporting of security concerns.

Processes and Policies

Poorly designed processes, absence of incident response plans, and insufficient staff training create vulnerabilities that technical controls alone cannot fix.

To summarize

- Risk management in this space is not a science, we are dealing with complexity and uncertainty
- Depending on audience and context your message might change
- Also considering the action you want and the impact you need

Risk management as a tool to help you

- Design a clear information security ambition (risk appetite statement)
- Design clear information security risk management processes (in order to balance risk the information available has to be correct and complete)

- Information security management must be a professional activity by design, to avoid getting into personal discussions.
- 100% security does not exist, so we need to manage expectations and trade-offs.